Lab 31 — Vulnerability Scanning, Confirmation and Rescan

> **SY0-701 Objective 4.3** — Explain various activities associated with vulnerability management.
>
> **Domain 4** — Security Operations (28%) · **Time:** ~15 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: Scan a deliberately weak local web server with Nmap (NSE) and Nikto, compare the uncredentialed and credentialed views, confirm each finding as a true or false positive, prioritise with CVSS and context, remediate, and rescan to validate.

You'll build: `/root/vuln/` containing the raw scan output, a triage sheet, a CVSS-prioritised findings register and a before/after validation report.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; tools installed in step 1.

> **Legal note:** Scan only systems you own or are explicitly authorised in writing to test. Unauthorised scanning can be an offence under the Singapore Computer Misuse Act 1993. Every scan in this lab targets `127.0.0.1` inside your own playground.

Background

- **Identification methods** include vulnerability scans, application security testing (static, dynamic, package monitoring), threat feeds, penetration tests, bug bounty programmes and system/process audits.
- An **uncredentialed** (non-authenticated) scan sees what an outside attacker sees, using banners and probes. A **credentialed** scan logs in and reads installed versions and configuration, so it is more accurate and finds missing patches.
- **Confirmation** separates a **true positive** from a **false positive** (reported but not real). A **false negative** (real but missed) is the most dangerous outcome, because nobody fixes what nobody sees.
- **Prioritise** with CVSS for severity, then adjust for exposure, environmental variables, industry and organisational impact, and risk tolerance.
- **Validation of remediation** means you rescan, verify and audit. Then you **report** on what is open, what is closed and what was excepted.

Steps

1. Install the scanners and the target

Nmap and Nikto are the scanners; Apache is the target. Nikto lives in Ubuntu's multiverse component.

```
apt-get update -qq && DEBIAN_FRONTEND=noninteractive apt-get install -y apache2 nmap nikto
curl
systemctl enable --now apache2
mkdir -p /root/vuln && curl -sI http://127.0.0.1 | head -3
```

2. Plant realistic weaknesses

Real servers drift. Here you expose the full version banner and leave a backup file in a directory that has listing enabled. Both are classic findings, and the secret is synthetic.

```
mkdir -p /var/www/html/backup
echo "db_user=webapp db_password=Synthetic-Lab-Only-123" > /var/www/html/backup/config.bak
sed -i 's/^ServerTokens .*/ServerTokens Full/; s/^ServerSignature .*/ServerSignature On/'
/etc/apache2/conf-available/security.conf
systemctl reload apache2
curl -s http://127.0.0.1/backup/ | grep -o 'config.bak' | head -1
```

3. Run an uncredentialed network scan with Nmap

Service and version detection (`-sV`) plus NSE scripts see the host exactly as a remote attacker would. The `vulners` script maps detected versions to CVE identifiers when the playground has internet access.

```
cd /root/vuln
nmap -sV -p 22,80 --script "http-headers,http-enum,http-server-header,vulners" 127.0.0.1 -
oN nmap-before.txt
grep -E 'open|/backup|Server:|CVE-' nmap-before.txt | head -20
```

4. Scan the web application with Nikto

Nikto tests thousands of known-dangerous files, headers and misconfigurations. Expect findings about missing security headers, the version banner and the indexed backup directory.

```
cd /root/vuln
nikto -h http://127.0.0.1 -o nikto-before.txt -Format txt
grep '^+' nikto-before.txt | head -20
```

5. Add the credentialed view

A credentialed scan logs in and reads local package state. Run the same check an agent or an authenticated scanner would, counting missing patches that no network probe can see.

```
cd /root/vuln
apache2 -v | head -1
apt-get -s upgrade 2>/dev/null | grep '^Inst' > missing-patches.txt
echo "Pending package updates (credentialed finding): $(wc -l < missing-patches.txt)"
grep -iE 'apache2|openssh|openssl|libc6' missing-patches.txt | head -5 || echo "No pending
updates for the key packages"
```

6. Confirm findings as true or false positives

Never ship raw scanner output. Re-test each finding by hand and record the verdict.

```
cd /root/vuln
curl -sI http://127.0.0.1 | grep -iE '^server:|^x-frame-options|^x-content-type-options' ;
echo "---"
curl -s -o /dev/null -w "backup listing HTTP %{http_code}\n" http://127.0.0.1/backup/
curl -s http://127.0.0.1/backup/config.bak | grep -c db_password
cat > triage.csv <<'EOF'
id,finding,source,verdict,evidence
F1,Directory listing exposes /backup/config.bak with credentials,nikto+nmap http-enum,True
positive,HTTP 200 and the file contains db_password
F2,Full Apache version disclosed in Server header,nikto+nmap,True positive,Server header
shows the full version and OS
F3,X-Frame-Options and X-Content-Type-Options missing,nikto,True positive,headers absent
in curl -I
F4,Version-based CVE match for Apache,nmap vulners,Needs review,Ubuntu backports fixes
without changing the version string - often a false positive
EOF
column -s, -t < triage.csv
```

7. Prioritise with CVSS and context

Score each confirmed finding, then adjust for context. F1 is internet-facing and leaks a credential, so it goes first even though its base score is not the highest possible.

```
cd /root/vuln
cat > findings-register.csv <<'EOF'
id,cvss_base,vector,exposure,asset_criticality,priority,due
F1,7.5,AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N,Internet-facing,High,P1,48 hours
F2,5.3,AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N,Internet-facing,High,P3,30 days
F3,4.3,AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N,Internet-facing,High,P3,30 days
F4,n/a,pending confirmation,Internet-facing,High,P2-verify,7 days
EOF
sort -t, -k6,6 findings-register.csv | column -s, -t
```

8. Remediate

Fix the root causes: remove the backup from the web root, disable indexing, hide the version and add the security headers. The `zz-` prefix makes the file load after Ubuntu's `security.conf`, so its settings win.

```
mkdir -p /root/vuln/quarantine && mv /var/www/html/backup/config.bak
/root/vuln/quarantine/
cat > /etc/apache2/conf-available/zz-secplus-hardening.conf <<'EOF'
ServerTokens Prod
ServerSignature Off
<Directory /var/www/html>
    Options -Indexes
</Directory>
Header always set X-Frame-Options "SAMEORIGIN"
Header always set X-Content-Type-Options "nosniff"
Header always set Referrer-Policy "no-referrer"
EOF
a2enmod -q headers && a2enconf -q zz-secplus-hardening && apache2ctl configtest &&
systemctl reload apache2
```

9. Rescan to validate and report

Validation means you repeat the same scans and compare. Then produce a short report for the asset owner.

```
cd /root/vuln
nikto -h http://127.0.0.1 -o nikto-after.txt -Format txt >/dev/null
nmap -sV -p 80 --script "http-headers,http-enum" 127.0.0.1 -oN nmap-after.txt >/dev/null
curl -s -o /dev/null -w "backup listing now HTTP %{http_code}\n" http://127.0.0.1/backup/
{
  echo "VULNERABILITY VALIDATION REPORT - host 127.0.0.1 - $(date -u '+%Y-%m-%d %H:%M
UTC')"
  echo "Nikto findings before: $(grep -c '^+' nikto-before.txt)  after: $(grep -c '^+'
nikto-after.txt)"
  echo "Header check after fix:"; curl -sI http://127.0.0.1 | grep -iE '^server:|^x-
frame|^x-content'
  echo "Pending OS patches (credentialed): $(wc -l < missing-patches.txt) - schedule in
the next maintenance window"
} | tee validation-report.txt
```

Test it

```
curl -sI http://127.0.0.1 | grep -iE '^server:|^x-frame-options|^x-content-type-options'
curl -s -o /dev/null -w "%{http_code}\n" http://127.0.0.1/backup/
cat /root/vuln/validation-report.txt
```

Expected: `Server: Apache` with no version, both security headers present, `/backup/` returns `403` or `404`, and the report shows fewer Nikto findings after the fix than before.

Troubleshooting

Symptom	Fix
`E: Unable to locate package nikto`	Enable multiverse with `add-apt-repository -y multiverse && apt-get update`, then repeat step 1.
`vulners` prints nothing	The script needs internet access to vulners.com. The rest of the scan is still valid; note it as a coverage gap.
`Invalid command 'Header'` on configtest	mod_headers is not enabled. Run `a2enmod headers` and reload.

Challenge

Write a one-page exception request for finding F4: the compensating control you would apply, the risk owner who signs it, and the expiry date that forces a review.

Reflection

The `vulners` script flagged a CVE on Apache, yet Ubuntu reports the package as fully patched. Is this a false positive or a false negative, and which kind of scan (credentialed or uncredentialed) settles the question?

Exam tips

- A credentialed scan gives more accurate results and fewer false positives; an uncredentialed scan shows the attacker's external view.
- False positive = alert with no real flaw (wasted effort). False negative = real flaw not reported (missed risk). The exam calls the second one the more dangerous.
- Validation of remediation = rescanning, auditing and verification. Remediation is not finished until a rescan confirms the fix.
- Nmap with NSE, Nikto, OpenVAS/Greenbone, Nessus and Qualys are all vulnerability scanners; a pentest goes further and actually exploits.

References

- NIST SP 800-115, Technical Guide to Information Security Testing and Assessment — https://csrc.nist.gov/pubs/sp/800/115/final
- Nmap NSE documentation — https://nmap.org/book/nse.html
- Nikto project — https://github.com/sullo/nikto
- FIRST CVSS v3.1 calculator — https://www.first.org/cvss/calculator/3.1
- OWASP Secure Headers Project — https://owasp.org/www-project-secure-headers/
